

Felipe Amorim Soria

Progetto S11/L5

Laboratorio 1

Obiettivo del Laboratorio

L'obiettivo di questo laboratorio è stato esplorare alcune delle funzionalità di base di PowerShell, inclusi comandi classici del Prompt dei Comandi (CMD), cmdlet nativi della piattaforma e strumenti di diagnostica di rete. L'esercitazione ha permesso di comprendere come PowerShell possa essere utilizzato per scopi amministrativi e di analisi del sistema.

Fasi e Comandi Eseguiti

1. Accesso alla Console di PowerShell

La sessione è stata avviata in PowerShell dal menu Start, con privilegi amministrativi.

2. Comando `dir`

Il comando `dir` è stato utilizzato per elencare file e cartelle nella directory corrente. Anche se è un comando tradizionale del CMD, in PowerShell viene interpretato come alias per:

`Get-ChildItem`

```
Windows PowerShell
Copyright (C) Microsoft Corporation. Tutti i diritti riservati.

Installa la versione più recente di PowerShell per nuove funzionalità e miglioramenti. https://aka.ms/PSWindows
PS C:\Users\develop> dir

Directory: C:\Users\develop

Mode                LastWriteTime         Length Name
----                -
d-r---          12/02/2025   14:37             Contacts
d-r---          12/02/2025   14:37             Desktop
d-r---          12/02/2025   14:37             Documents
d-r---          10/04/2025   15:32             Downloads
d-r---          12/02/2025   14:37             Favorites
d-r---          12/02/2025   14:37             Links
d-r---          12/02/2025   14:37             Music
d-r---          12/02/2025   14:44             OneDrive
d-r---          12/02/2025   14:37             Pictures
d-r---          12/02/2025   14:37             Saved Games
d-r---          12/02/2025   14:42             Searches
d-r---          12/02/2025   14:37             Videos
```

3. Comando **ping**

È stato eseguito un test di connettività con il comando **ping**, utile per verificare la comunicazione con un altro host nella rete.

ping

Questo comando è nativo del CMD, ma funziona anche in PowerShell come strumento di diagnostica.

```
PS C:\Users\develop> ping

Sintassi: ping [-t] [-a] [-n count] [-l size] [-f] [-i TTL] [-v TOS]
            [-r count] [-s count] [[-j host-list] | [-k host-list]]
            [-w timeout] [-R] [-S srcaddr] [-c compartment]
            [-4] [-6] target_name

Opzioni:
    -t                Esegue il ping dell'host specificato finché non viene
                       interrotto. Per visualizzare le statistiche e continuare -
                       digitare Control-Break; Per interrompere - digitare
                       Control-C.
    -a                Risolve gli indirizzi in nomi host.
    -n count          Numero di richieste echo da inviare.
    -l size           Dimensioni del buffer di invio.
    -f                Imposta il contrassegno per la disattivazione della
                       frammentazione nel pacchetto (solo IPv4).
    -i TTL            Durata (TTL, Time To Live).
    -v TOS            Tipo di servizio (TOS, Type Of Service) (solo IPv4.
                       Questa impostazione è deprecata e non ha alcun effetto sul
                       campo del tipo di servizio nell'intestazione IP).
    -r count          Registra la route per il conteggio degli hop (solo IPv4).
    -s count          Timestamp per il conteggio degli hop (solo IPv4).
    -j host-list      Route di origine libera lungo l'elenco host (solo IPv4).
    -k host-list      Route di origine vincolata lungo l'elenco host (solo IPv4).
    -w timeout        Timeout in millisecondi per l'attesa di ogni risposta.
    -R               Usa l'intestazione di routing anche per il test del routing
                       inverso (solo IPv6). In base a RFC 5095 l'utilizzo di questa
                       intestazione di routing è deprecato. Alcuni sistemi
                       potrebbero ignorare le richieste echo se viene utilizzata
                       questa intestazione.
    -S srcaddr        Indirizzo di origine da utilizzare.
    -c compartment    Identificatore del raggruppamento di routing.
    -p               Esegue il ping dell'indirizzo di un provider
```

4. Comando **Get-Alias dir**

È stato usato per verificare il cmdlet originale collegato all'alias **dir**. Il risultato ha confermato che:

dir → **Get-ChildItem**

```
PS C:\Users\develop> Get-Alias dir
```

CommandType	Name	Version	Source
-----	----	-----	-----
Alias	dir -> Get-ChildItem		

5. Comando **netstat -h**

È stato eseguito il comando:

```
netstat -h
```

Questo ha mostrato il conteggio degli *socket handle* per processo (PID), permettendo di analizzare quanti socket ogni processo stava utilizzando attivamente.

```
PS C:\Users\develop> netstat -h
```

Socket Handle Count

PID	Count	Closing Count
3080	4	0
1552	4	0
816	4	0
4156	4	0
836	4	0
3396	1	0
3404	1	0
1384	1	0
4200	1	0
4736	1	0
1688	4	0
6044	1	0
416	9	0
672	4	0
7840	4	0
1972	8	0
4040	2	0
7380	9	0
7392	1	0
8936	2	0
9976	2	0
5884	8	0

6. Comando **netstat -r**

netstat -r

Questo comando ha mostrato la tabella di routing del sistema, includendo informazioni sulle interfacce di rete, gateway, metriche e percorsi attivi. È utile per comprendere come il traffico di rete viene instradato all'interno del sistema e verso l'esterno, facilitando la diagnosi di problemi di connettività o configurazioni errate della rete.

```
C:\Users\develop>netstat -r
=====
Elenco interfacce
 7...fa ab c9 1d d2 96 .....Red Hat VirtIO Ethernet Adapter
 1.....Software Loopback Interface 1
=====

IPv4 Tabella route
=====
Route attive:
      Indirizzo rete      Mask      Gateway      Interfaccia Metrica
      0.0.0.0            0.0.0.0    192.168.50.1  192.168.50.80  271
      127.0.0.0          255.0.0.0    On-link      127.0.0.1     331
      127.0.0.1  255.255.255.255    On-link      127.0.0.1     331
 127.255.255.255  255.255.255.255    On-link      127.0.0.1     331
   192.168.50.0    255.255.255.0    On-link      192.168.50.80  271
   192.168.50.80  255.255.255.255    On-link      192.168.50.80  271
   192.168.50.255  255.255.255.255    On-link      192.168.50.80  271
      224.0.0.0        240.0.0.0    On-link      127.0.0.1     331
      224.0.0.0        240.0.0.0    On-link      192.168.50.80  271
 255.255.255.255  255.255.255.255    On-link      127.0.0.1     331
 255.255.255.255  255.255.255.255    On-link      192.168.50.80  271
=====
Route permanenti:
      Indirizzo rete      Mask      Indir. gateway Metrica
      0.0.0.0            0.0.0.0    192.168.50.1  Predefinito
=====
```

```

IPv6 Tabella route
=====
Route attive:
Interf Metrica Rete Destinazione Gateway
7 271 ::/0 fe80::a2b5:3cff:fe50:1f8a
1 331 ::1/128 On-link
7 271 2001:b07:6463:c4ba::/64 On-link
7 271 2001:b07:6463:c4ba::/64 fe80::a2b5:3cff:fe50:1f8a
7 271 2001:b07:6463:c4ba:7c4d:17a4:6e11:8020/128
On-link
7 271 2001:b07:6463:c4ba:c66e:ed9d:3ff3:1718/128
On-link
7 271 fe80::/64 On-link
7 271 fe80::291b:7bde:3a58:e38c/128
On-link
1 331 ff00::/8 On-link
7 271 ff00::/8 On-link
=====
Route permanenti:
Nessuna

```

7. Comando `netstat -abno`

È stato eseguito il comando avanzato:

`netstat -abno`

```

PS C:\Users\develop> netstat -abno

Connessioni attive

Proto Indirizzo locale Indirizzo esterno Stato PID
TCP 0.0.0.0:135 0.0.0.0:0 LISTENING 416
RpcSs
[svchost.exe]
TCP 0.0.0.0:445 0.0.0.0:0 LISTENING 4
Impossibile ottenere informazioni sulla proprietà
TCP 0.0.0.0:5040 0.0.0.0:0 LISTENING 4156
CDPSvc
[svchost.exe]
TCP 0.0.0.0:49664 0.0.0.0:0 LISTENING 836
Impossibile ottenere informazioni sulla proprietà
TCP 0.0.0.0:49665 0.0.0.0:0 LISTENING 672
Impossibile ottenere informazioni sulla proprietà
TCP 0.0.0.0:49666 0.0.0.0:0 LISTENING 1688
EventLog
[svchost.exe]
TCP 0.0.0.0:49667 0.0.0.0:0 LISTENING 1552
Schedule
[svchost.exe]
TCP 0.0.0.0:49668 0.0.0.0:0 LISTENING 3080
[spoolsv.exe]
TCP 0.0.0.0:49676 0.0.0.0:0 LISTENING 816
Impossibile ottenere informazioni sulla proprietà
TCP 127.0.0.1:9843 0.0.0.0:0 LISTENING 4200
[spice-webdavd.exe]
TCP 127.0.0.1:58296 127.0.0.1:9843 TIME_WAIT 0

```

Che ha mostrato:

- Indirizzi locali e remoti
- Stato della connessione
- Nome dell'eseguibile (-b)
- PID del processo (-o)
- Tutte le porte (-a)
- Senza risoluzione dei nomi (-n)

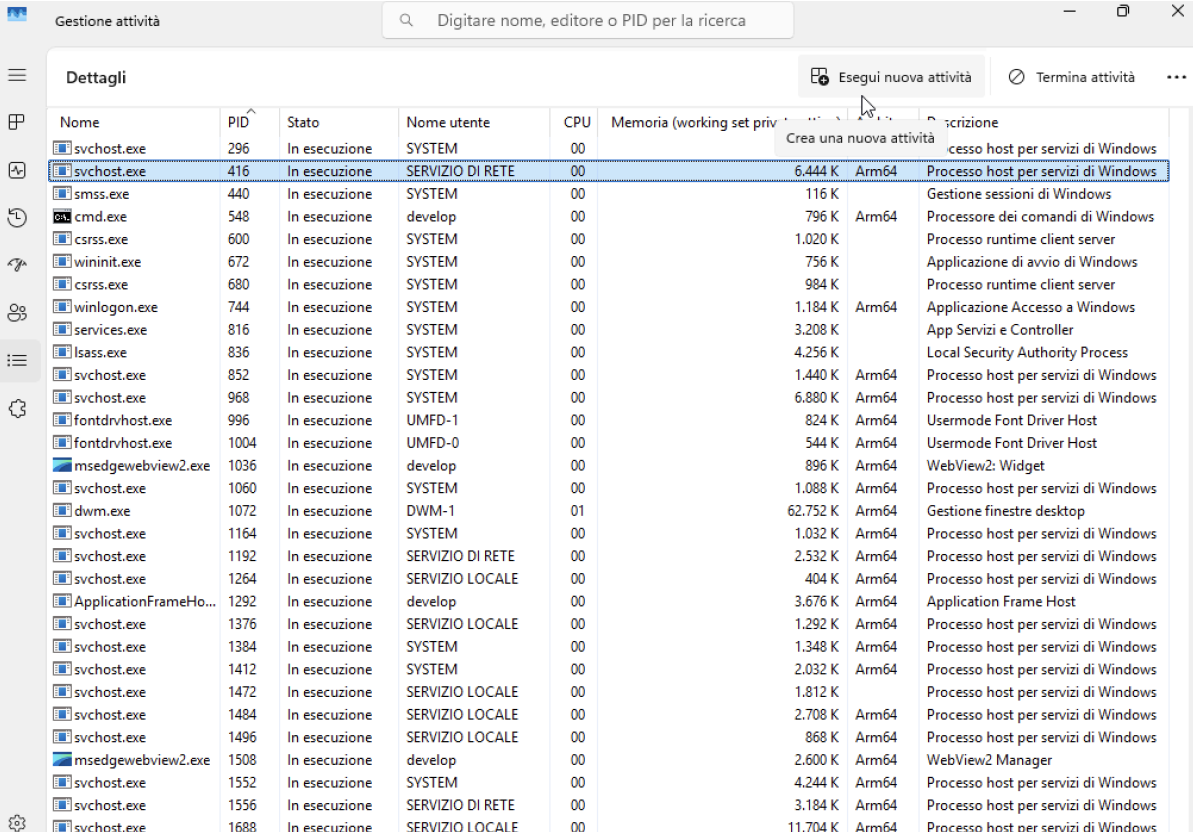
È uno strumento utile per analizzare quali applicazioni usano la rete e quali porte sono in ascolto o attive.

Successivamente, **è stato selezionato uno dei processi** (nell'esempio, il **PID 416**) per un'analisi più approfondita. È stato quindi aperto il **Task Manager** e selezionata la scheda **Details**.

Le azioni svolte sono state:

- Clic sull'intestazione della colonna **PID** per ordinare i processi in base all'ID
- Ricerca del processo associato al PID selezionato (nel caso, **svchost.exe**)
- Click con il tasto destro sul processo e selezione di **Properties** per visualizzare maggiori informazioni sull'eseguibile, sul percorso e sul servizio associato

Questa operazione ha permesso di identificare con precisione **quale applicazione o servizio** stava utilizzando le connessioni di rete rilevate con **netstat**.



Nome	PID	Stato	Nome utente	CPU	Memoria (working set priv.)	Processore	Descrizione
svchost.exe	296	In esecuzione	SYSTEM	00			
svchost.exe	416	In esecuzione	SERVIZIO DI RETE	00	6.444 K	Arm64	Processo host per servizi di Windows
smss.exe	440	In esecuzione	SYSTEM	00	116 K		Gestione sessioni di Windows
cmd.exe	548	In esecuzione	develop	00	796 K	Arm64	Processore dei comandi di Windows
csrss.exe	600	In esecuzione	SYSTEM	00	1.020 K		Processo runtime client server
wininit.exe	672	In esecuzione	SYSTEM	00	756 K		Applicazione di avvio di Windows
csrss.exe	680	In esecuzione	SYSTEM	00	984 K		Processo runtime client server
winlogon.exe	744	In esecuzione	SYSTEM	00	1.184 K	Arm64	Applicazione Accesso a Windows
services.exe	816	In esecuzione	SYSTEM	00	3.208 K		App Servizi e Controller
lsass.exe	836	In esecuzione	SYSTEM	00	4.256 K		Local Security Authority Process
svchost.exe	852	In esecuzione	SYSTEM	00	1.440 K	Arm64	Processo host per servizi di Windows
svchost.exe	968	In esecuzione	SYSTEM	00	6.880 K	Arm64	Processo host per servizi di Windows
fontdrvhost.exe	996	In esecuzione	UMFD-1	00	824 K	Arm64	Usermode Font Driver Host
fontdrvhost.exe	1004	In esecuzione	UMFD-0	00	544 K	Arm64	Usermode Font Driver Host
msedgewebview2.exe	1036	In esecuzione	develop	00	896 K	Arm64	WebView2: Widget
svchost.exe	1060	In esecuzione	SYSTEM	00	1.088 K	Arm64	Processo host per servizi di Windows
dwm.exe	1072	In esecuzione	DWM-1	01	62.752 K	Arm64	Gestione finestre desktop
svchost.exe	1164	In esecuzione	SYSTEM	00	1.032 K	Arm64	Processo host per servizi di Windows
svchost.exe	1192	In esecuzione	SERVIZIO DI RETE	00	2.532 K	Arm64	Processo host per servizi di Windows
svchost.exe	1264	In esecuzione	SERVIZIO LOCALE	00	404 K	Arm64	Processo host per servizi di Windows
ApplicationFrameHost.exe	1292	In esecuzione	develop	00	3.676 K	Arm64	Application Frame Host
svchost.exe	1376	In esecuzione	SERVIZIO LOCALE	00	1.292 K	Arm64	Processo host per servizi di Windows
svchost.exe	1384	In esecuzione	SYSTEM	00	1.348 K	Arm64	Processo host per servizi di Windows
svchost.exe	1412	In esecuzione	SYSTEM	00	2.032 K	Arm64	Processo host per servizi di Windows
svchost.exe	1472	In esecuzione	SERVIZIO LOCALE	00	1.812 K		Processo host per servizi di Windows
svchost.exe	1484	In esecuzione	SERVIZIO LOCALE	00	2.708 K	Arm64	Processo host per servizi di Windows
svchost.exe	1496	In esecuzione	SERVIZIO LOCALE	00	868 K	Arm64	Processo host per servizi di Windows
msedgewebview2.exe	1508	In esecuzione	develop	00	2.600 K	Arm64	WebView2 Manager
svchost.exe	1552	In esecuzione	SYSTEM	00	4.244 K	Arm64	Processo host per servizi di Windows
svchost.exe	1556	In esecuzione	SERVIZIO DI RETE	00	3.184 K	Arm64	Processo host per servizi di Windows
svchost.exe	1688	In esecuzione	SERVIZIO LOCALE	00	11.704 K	Arm64	Processo host per servizi di Windows

8. Comando **Clear-RecycleBin**

Dopo la correzione, il cmdlet è stato eseguito correttamente:

```
Clear-RecycleBin -Force
```

Questo ha svuotato il Cestino senza richiedere conferma, liberando spazio sul disco.

Conclusione

Il laboratorio ha permesso di comprendere l'uso combinato di comandi tradizionali e cmdlet moderni in PowerShell. Sono state testate funzionalità di:

- Navigazione file
- Diagnostica rete (**ping**, **netstat**)
- Consultazione alias
- Gestione del sistema (**Clear-RecycleBin**)

L'attività ha evidenziato la flessibilità e la potenza del PowerShell come strumento per amministratori di sistema e professionisti della cybersicurezza.

Laboratorio 2

Fasi Svolte

Parte 1: Cattura e Analisi del Traffico HTTP

Avvio della cattura con tcpdump

È stato eseguito il seguente comando per avviare la cattura del traffico HTTP sull'interfaccia di rete attiva (`eth0`), salvando il file in formato `.pcap`:

```
sudo tcpdump -i eth0 -s 0 -w httpdump.pcap
```

Generazione del traffico HTTP

In un browser web, è stato aperto il seguente sito vulnerabile (in HTTP):

```
http://testphp.vulnweb.com/login.php
```

Dopo aver interrotto la cattura, il file `httpdump.pcap` è stato aperto in **Wireshark**.

È stato applicato il filtro:

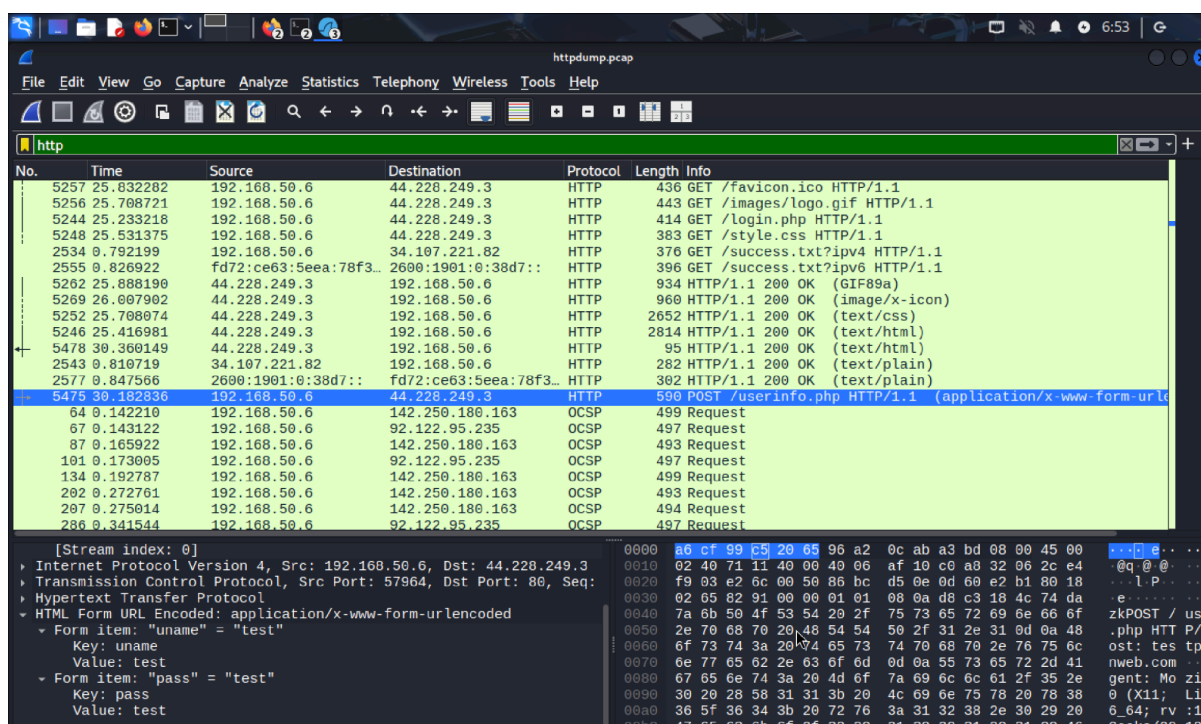
`nginx`

CopiaModifica

`http`

Questo ha permesso di visualizzare le richieste e risposte HTTP in **chiaro**, inclusi:

- Metodi (GET/POST)
- URL visitati
- Dati inviati nei form
- Header delle richieste



Parte 2: Cattura e Analisi del Traffico HTTPS

Avvio della cattura HTTPS con tcpdump

È stato eseguito un secondo comando per catturare il traffico HTTPS:

```
sudo tcpdump -i eth0 -s 0 -w httpsdump.pcap
```

1. Navigazione su un sito HTTPS

Anche se non specificato, è stato visitato un sito sicuro qualsiasi (es.

<https://google.com>) per generare traffico cifrato.

2. Analisi con Wireshark

Il file `httpsdump.pcap` è stato aperto in **Wireshark**.

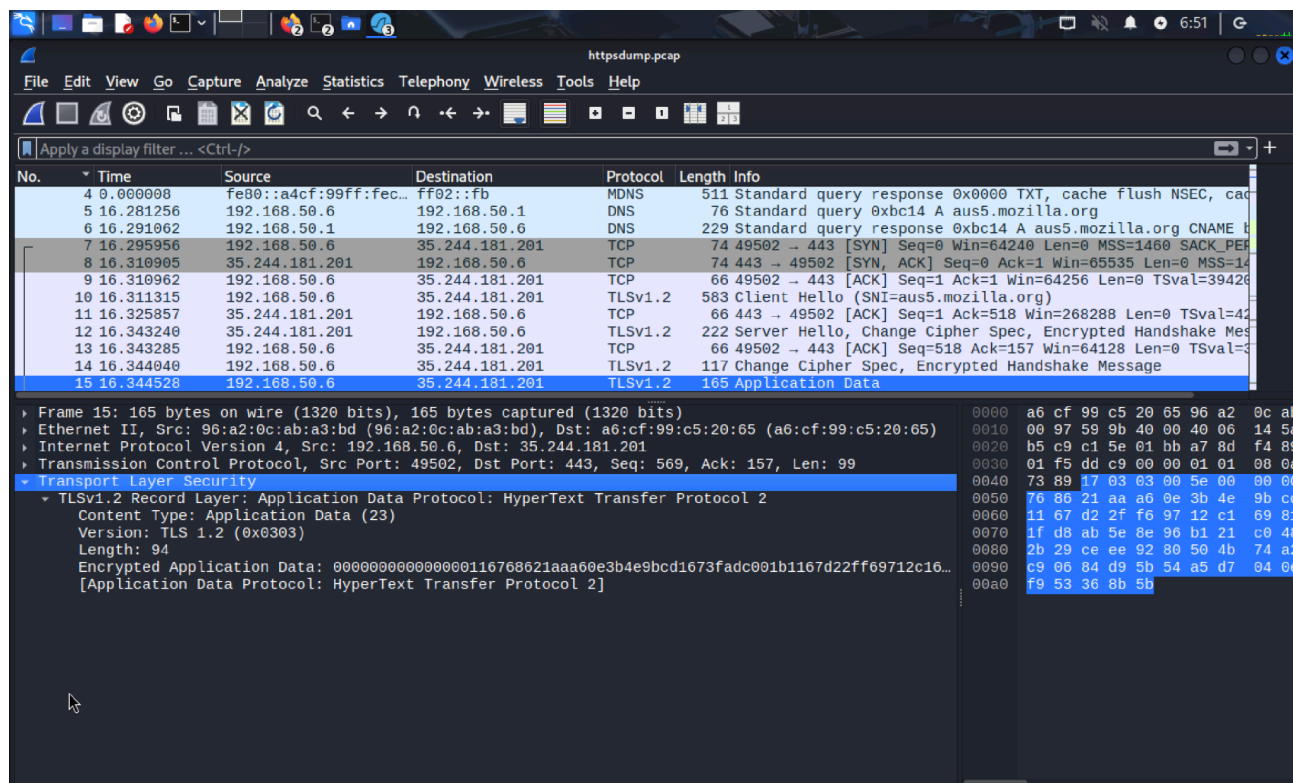
È stato applicato il filtro:

```
tls
```

3. I pacchetti visualizzati includono:

- Handshake iniziale (Client Hello, Server Hello)
- Scambio del certificato
- Pacchetti di tipo **Encrypted Application Data**

4. Non è stato possibile leggere i contenuti reali delle comunicazioni, a causa della cifratura garantita da HTTPS.



✓ Conclusione

Attraverso questo laboratorio, è stato possibile comprendere le **differenze pratiche** tra il traffico HTTP e HTTPS:

- **HTTP**: tutto il contenuto è visibile, inclusi nomi utente, password e dati di navigazione.
- **HTTPS**: protegge la comunicazione grazie alla cifratura, rendendo il contenuto dei pacchetti illeggibile durante l'analisi.

L'uso combinato di **tcpdump** per la cattura e di **Wireshark** per l'analisi ha fornito un'esperienza concreta e professionale, molto utile in ambito **cybersecurity** e **analisi forense**.

Bonus 2

Relazione di Laboratorio: Analisi di un Attacco SQL Injection con Wireshark

Obiettivo del Laboratorio

L'obiettivo di questo laboratorio è stato quello di analizzare un **attacco SQL Injection** avvenuto in passato, utilizzando un file **PCAP** contenente il traffico di rete registrato. Attraverso l'uso di **Wireshark**, è stato possibile ricostruire ogni fase dell'attacco, dalla prima richiesta sospetta fino all'esfiltrazione delle informazioni dal database.

1: Apertura del file PCAP in Wireshark

- È stata avviata la **macchina virtuale CyberOps Workstation**.
- Tramite il percorso:
Applications > CyberOPS > Wireshark, è stata aperta l'applicazione.

Nella schermata principale di Wireshark, è stato cliccato **Open**, ed è stato selezionato il file:

`/home/analyst/lab.support.files/SQL_Lab.pcap`

- Il file ha mostrato traffico di rete relativo a un attacco SQL durato circa **8 minuti (441 secondi)**.
-

2: Visualizzazione dell'attacco SQL Injection

- Sono stati applicati **filtri HTTP** per individuare le richieste web sospette.
 - È stato possibile identificare **query SQL manipulate** nelle URL o nei parametri di form (es. `id=1' OR '1'='1`), tipiche di un attacco SQL Injection.
-

3: Continuazione dell'attacco

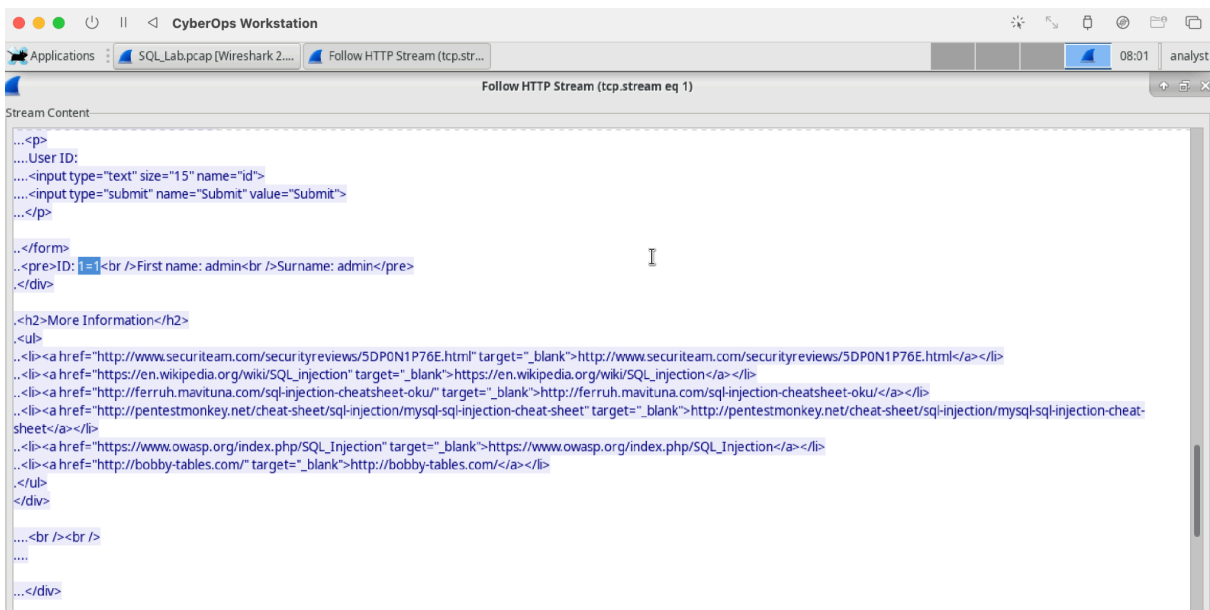
- Sono emerse richieste multiple da parte dell'attaccante, con **query SQL modificate** per esplorare il contenuto del database.
 - Le risposte del server confermavano che il comando SQL era stato eseguito, suggerendo che il server era **vulnerabile**.
-

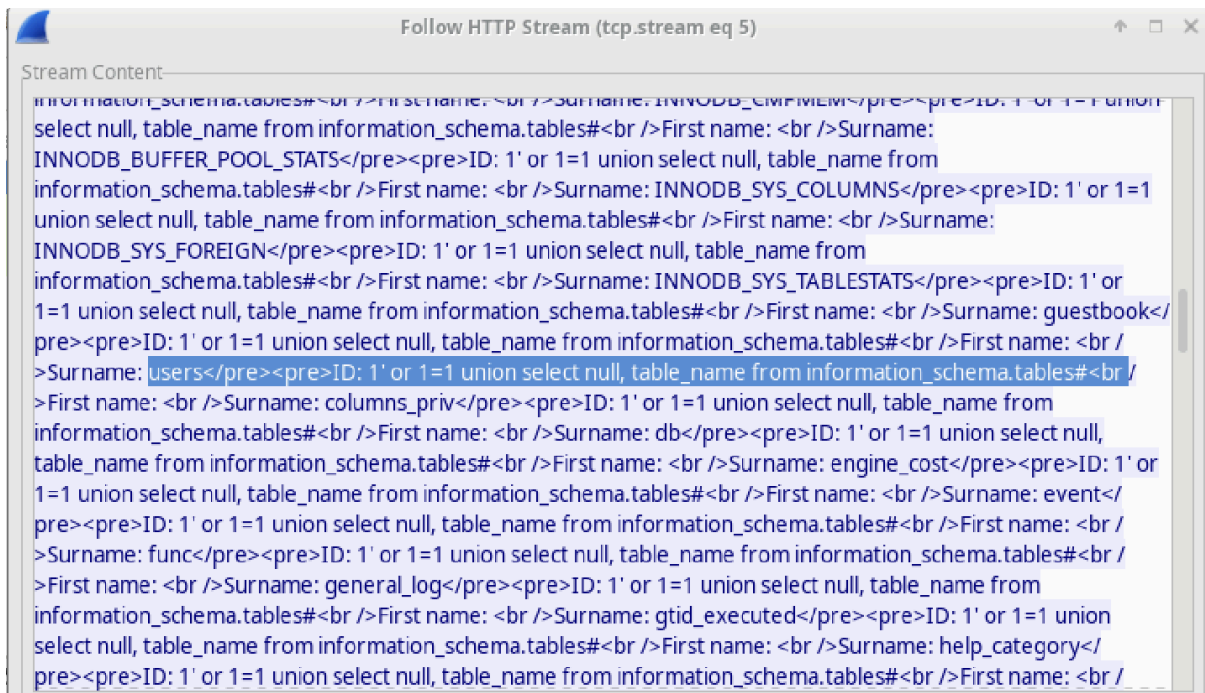
4: Estrazione di Informazioni di Sistema

- In questa fase, l'attaccante ha eseguito comandi SQL per ottenere **informazioni sul sistema**, come versione del database, nome del sistema operativo, utente attivo ecc.
 - Questi dati sono stati visibili nelle risposte HTTP.
-

5: Esplorazione delle Tabelle del Database

- Sono stati identificati comandi SQL per ottenere **nomi di tabelle**, colonne e dati sensibili.
 - L'attaccante ha probabilmente usato funzioni come `information_schema.tables` per mappare la struttura del database.
-





Applications CrackStation - Online Password Hash Cracking - MD5, SHA1, Linux, Rainbow Tables, etc. - Mozilla Firefox

CrackStation - Online Password Hash Cracking - MD5, SHA1, Linux, Rainbow Tables, etc. - Mozilla Firefox

https://crackstation.net

CrackStation

Defuse.ca · Twitter

CrackStation Password Hashing Security Defuse Security

Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

8d3533d75ae2c3966d7e0d4fcc69216b

I'm not a robot reCAPTCHA

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
8d3533d75ae2c3966d7e0d4fcc69216b	md5	charley

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

Download CrackStation's Wordlist

How CrackStation Works

CrackStation uses massive pre-computed lookup tables to crack password hashes. These tables store a mapping between the hash of a password, and the correct password for that hash. The hash values are indexed so that it is possible to quickly search the database for a given hash. If the hash is present in the database, the password can be recovered in a fraction of a second. This only

6: Conclusione dell'attacco

- Il traffico finale ha mostrato **interazioni di lettura** con i dati presenti nel database, segnalando una **potenziale esfiltrazione di informazioni**.
- Dopo l'ultima richiesta, il traffico HTTP si è interrotto, concludendo l'attacco.

Conclusione

Questo laboratorio ha fornito una panoramica pratica su come **un attacco SQL Injection** può essere eseguito e rilevato attraverso un'analisi forense del traffico di rete.

Utilizzando **Wireshark** e il file **SQL_Lab.pcap**, è stato possibile:

- Identificare le fasi dell'attacco
- Analizzare le query SQL malevole
- Valutare il livello di compromissione del server

L'attività ha rafforzato la comprensione della **cyber difesa**, dell'**analisi forense di rete** e dell'importanza della **valutazione delle vulnerabilità applicative**.